Lab 48 — Compliance Audit with OpenSCAP

> **SY0-701 Objective 5.4** — Summarize elements of effective security compliance
>
> **Domain 5** — Security Program Management and Oversight (20%) · **Time:** ~40 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

Goal: Produce machine-checked compliance evidence and remediate a failed control.

You'll build: An OpenSCAP scan of an Ubuntu host against a CIS profile, a human-readable HTML report, an auto-generated remediation script and one applied fix.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; SCAP content and the `oscap` scanner installed in step 1.

Background

- **Compliance** is proving you meet the laws, regulations and standards that apply to you — and keeping the evidence.
- **SCAP** (Security Content Automation Protocol) is the open standard that makes compliance machine-readable; `oscap` reads an XCCDF checklist and reports pass/fail.
- A single profile (such as CIS Level 1) produces three outputs: an **audit**, a **remediation** script and a human **report**.
- **Compliance monitoring** uses **automation** to produce continuous evidence rather than a once-a-year snapshot; the report is your **attestation** evidence.
- Auto-remediation can break running services, so it is reviewed before it is run (**due care**).

Steps

1. Install the SCAP Security Guide content and OpenSCAP scanner

The `oscap` binary ships in `libopenscap8` on 22.04 and `openscap-scanner` on 24.04; install whichever this release provides.

```
apt-get update -qq
apt-get install -y ssg-base ssg-debian ssg-debderived
apt-get install -y openscap-scanner || apt-get install -y libopenscap8
ls /usr/share/xml/scap/ssg/content/ | grep ubuntu
```

2. Select the Ubuntu SCAP datastream

The datastream bundles the rules, profiles and tests into one file.

```
DS=$(ls /usr/share/xml/scap/ssg/content/ssg-ubuntu*-ds.xml | head -1)
echo "Using $DS"
```

3. List available compliance profiles

A profile is a named subset of rules, selected on the command line.

```
oscap info "$DS" | grep -A1 -i profile | head -20
```

```
Profiles:
  xccdf_org.ssgproject.content_profile_cis_level1_server
  xccdf_org.ssgproject.content_profile_standard
  ...
```

4. Run the CIS Level 1 audit

This evaluates the host and writes both machine evidence (ARF) and a human report.

```
oscap xccdf eval \
  --profile xccdf_org.ssgproject.content_profile_cis_level1_server \
  --results-arf arf.xml \
  --report report.html \
  "$DS" 2>&1 | tail -10
ls -l report.html arf.xml
```

5. Generate the auto-remediation script

SCAP can emit a fix script straight from the same profile — review before running.

```
oscap xccdf generate fix \
  --profile xccdf_org.ssgproject.content_profile_cis_level1_server \
  --output remediate.sh "$DS"
head -20 remediate.sh
```

6. Apply one fix and re-check the rule

Remediate a single, safe control, then re-evaluate just that rule to confirm.

```
apt-get purge -y telnet 2>/dev/null || true
oscap xccdf eval \
  --rule xccdf_org.ssgproject.content_rule_package_telnet_removed \
  "$DS" 2>&1 | grep -i result
```

Test it

```
test -s report.html && echo "HTML report generated"
grep -ci 'pass\|fail' report.html
```

Expected: `report.html` exists and contains pass/fail results per control, and the single rule re-check in step 6 reports `pass` after `telnet` is removed.

Troubleshooting

Symptom	Fix
`oscap: command not found`	Install the scanner: `apt-get install -y libopenscap8` (or `openscap-scanner`).
No `ssg-ubuntu*-ds.xml` file found	The SSG content package did not install; re-run step 1 and check `ssg-debderived`.
Scan reports `notchecked` for many rules	Normal in a container — some rules target bare-metal; focus on the ones that evaluate.

Challenge

Re-run the full scan against the `standard` profile instead of CIS Level 1 and note how many fewer controls it checks, and why a lighter profile might suit a dev host.

Reflection

Objective 5.4 lists automation under compliance monitoring. How does an `oscap` scan provide *continuous* evidence that a once-a-year manual checklist cannot?

Exam tips

- SCAP/XCCDF turns a benchmark (CIS, STIG) into an automated pass/fail audit with evidence.
- Compliance monitoring favours automation for continuous evidence; the report is attestation evidence.
- Review auto-remediation before running it — that judgement is *due care*.
- Non-compliance consequences: fines, sanctions, reputational damage, loss of licence, contractual impacts.

References

- ComplianceAsCode / SCAP Security Guide — https://github.com/ComplianceAsCode/content
- NIST SCAP — https://csrc.nist.gov/projects/security-content-automation-protocol
- CIS Benchmarks — https://www.cisecurity.org/cis-benchmarks
